

**Sri Lanka Institute of Information Technology**



**Enterprise Standards for Information Security - IE3102**

## **Checklists**

**IT23269484 – T. H. Ranasinghe**

# ISO 27001:2022 Implementation Checklists Report

## 1. Introduction

Information security as a building block to digital resilience. The ISO/IEC 27001:2022 standard sets out the internationally recognized requirements for an Information Security Management System (ISMS). In order to be compliant, organizations must evidence a consistent and transparent security risk management effort in people, process, and technology.

This document is a checklist report in detail and step by step as an implementation of ISO 27001:2022. Every check list matches the steps of PDCA(Plan-Do-Check-Act) cycle as well as annex A (4 - 10) of the standard. These checklists ensure that all main processes from risk Management till documentary, Monitoring and continuous improvement are auditable and quantifiable.

This paper is organized as follows:

- Implementation framework and PDCA overview
- Individual checklists for each clause
- Detailed explanations for each table
- Templates to help with risk and incident management
- Integration and continual improvement guidance

The checklists and explanations in this publication are based on widely accepted ISO standards, industry best practices, trusted technology sources, as well as academic research on risk-driven information security management. They are based on contemporary interpretations of ISO 27001:2022 principles and are considering perspectives on governance, control alignment and ongoing improvement from across the global business environment. The content is both practitioner ready and academically sound.

## 2. ISMS Implementation Framework

ISO 27001 is based on the PDCA (Plan–Do–Check–Act) Process model, which ensures continual improvement and allows the ISMS to be fit for purpose.

| Phase | Focus Area                                                       | Key Activities                                                                                           |
|-------|------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------|
| Plan  | Establish the ISMS scope, context, policies, and risk framework. | Define organizational context, leadership roles, and perform risk assessment.                            |
| Do    | Implement the operational controls.                              | Deploy controls from Annex A, manage incidents, train staff, and ensure technical and physical security. |
| Check | Monitor and evaluate ISMS performance.                           | Conduct internal audits, management reviews, and compliance monitoring.                                  |
| Act   | Enhance performance through improvement.                         | Implement corrective actions, update controls, and improve the ISMS based on findings.                   |

This model shows the periodic nature of ISO 27001 deployment. It makes sure that the ISMS grows and develops with new threats and business needs. Plan and do are about the basics, Check is monitoring compliance and Act stands for continuous improvement. It is the basis of all checklists herein.

## 3. Context and Leadership Checklist (Clauses 4 & 5)

| Checklist Item                                                                                   | Yes/No | Remarks/Evidence |
|--------------------------------------------------------------------------------------------------|--------|------------------|
| Have internal and external issues affecting information security been identified and documented? |        |                  |
| Are interested parties and their security expectations determined?                               |        |                  |
| Has the ISMS scope been clearly defined, including boundaries and interfaces?                    |        |                  |
| Is top management actively demonstrating leadership and commitment?                              |        |                  |
| Has an Information Security Policy been approved and communicated?                               |        |                  |
| Are ISMS roles, responsibilities, and authorities clearly assigned?                              |        |                  |
| Is information security integrated into organizational strategy and planning?                    |        |                  |
| Are regular management reviews conducted and documented?                                         |        |                  |

This one provides management reporting and governance alignment with ISMS scope. Clauses 4 and 5 ISO 27001:2022 focus on leadership responsibility and embedding ISMS aims in the business plan. ISMS efforts die on the vine without leadership support, visibility, funding, or control.

#### 4. Risk Assessment and Treatment Checklist (Clause 6)

| Checklist Item                                                               | Yes/No | Remarks/Evidence |
|------------------------------------------------------------------------------|--------|------------------|
| Is there a documented risk assessment process based on ISO 31000 principles? |        |                  |
| Are assets, threats, vulnerabilities, and impacts identified and listed?     |        |                  |
| Are evaluation criteria (likelihood × impact) defined for quantifying risk?  |        |                  |
| Are unacceptable risks prioritized and addressed with treatment plans?       |        |                  |
| Has the Statement of Applicability (SoA) been created and approved?          |        |                  |
| Are selected controls from Annex A properly justified?                       |        |                  |
| Are residual risks documented and accepted by management?                    |        |                  |
| Is there a continuous review cycle for risk assessment results?              |        |                  |

The heart of ISO 27001 is risk management. This list allows controlling risks at all stages of the process in accordance with ISO 31000.

It incorporates a risk management approach, which focuses on process and structure, and leads to proactive prevention, rather than reactive response.

The SoA is the record of whether/how 93 controls in Annex A are implemented and the justification.

## 5. Support and Resource Checklist (Clause 7)

| Checklist Item                                                                      | Yes/No | Remarks/Evidence |
|-------------------------------------------------------------------------------------|--------|------------------|
| Have adequate financial and human resources been allocated for ISMS activities?     |        |                  |
| Are ISMS responsibilities defined and documented?                                   |        |                  |
| Have employees received security awareness and competency-based training?           |        |                  |
| Are training outcomes monitored and retained as records?                            |        |                  |
| Are internal and external communication channels established for ISMS updates?      |        |                  |
| Are documentation control procedures (creation, approval, and versioning) in place? |        |                  |

Its clause 7 makes sure that ISMS will only be successful when people not technology are involved. This checklist ensures that employees receive training, resources are deployed, and documentation is maintained in an orderly manner. Knowledge and communication also help make sure everyone knows their role in the process, fostering an environment of culture-first security across your company.

## 6. Operational Control Implementation Checklist (Clause 8 + Annex A)

This table implements the “Do” cycle of PDCA, by checking the controls that have been put in place (from Annex A (A.5 – A. 18). It provides technical, physical and procedural security. This description (e.g., asset management (A.8), access control (A.9), cryptography (A.10), supplier relationships (– A.15), operational planning ) is most prevalent among. It is important that this check list be part of the tools to prove conformity during the certification audits.

| Checklist Item                                                            | Yes/No | Remarks/Evidence |
|---------------------------------------------------------------------------|--------|------------------|
| Are information security policies implemented across departments?         |        |                  |
| Is there a maintained and updated asset inventory with ownership details? |        |                  |
| Are user access controls enforced using the principle of least privilege? |        |                  |
| Are encryption and cryptographic controls implemented for sensitive data? |        |                  |
| Are physical access restrictions and monitoring mechanisms in place?      |        |                  |
| Are system updates, patches, and vulnerability fixes regularly applied?   |        |                  |
| Are data backup and restoration procedures validated?                     |        |                  |
| Are suppliers evaluated and contracts include security clauses?           |        |                  |
| Are incident response and change management procedures documented?        |        |                  |

## 7. Internal Audit Checklist (Clause 9.2)

| Checklist Item                                                                | Yes/No | Remarks/Evidence |
|-------------------------------------------------------------------------------|--------|------------------|
| Is an internal audit schedule developed and approved annually?                |        |                  |
| Are auditors trained, competent, and independent from operations?             |        |                  |
| Is the audit scope clearly defined (processes, departments, timeframes)?      |        |                  |
| Are audit checklists used to verify control implementation and effectiveness? |        |                  |
| Are audit findings documented, analyzed, and assigned for corrective actions? |        |                  |
| Are management reviews conducted on audit outcomes?                           |        |                  |

Internal audits validate whether the ISMS meets both ISO 27001 requirements and internal policy objectives.

This checklist guarantees consistent audit execution, transparency, and continual improvement.

As Aleksandrova (2020) notes, frequent internal audits reduce the risk of nonconformities during certification and build organizational maturity.

## 8. Incident Management Checklist (Annex A.16)

| Checklist Item                                                         | Yes/No | Remarks/Evidence |
|------------------------------------------------------------------------|--------|------------------|
| Is there a formally approved Incident Management Policy?               |        |                  |
| Are incidents classified by type and severity (low, medium, high)?     |        |                  |
| Are incident reporting channels available to all employees?            |        |                  |
| Are incident logs maintained with timestamps and resolution details?   |        |                  |
| Is root cause analysis performed for major incidents?                  |        |                  |
| Are lessons learned incorporated into policy updates?                  |        |                  |
| Is incident response tested through simulations or tabletop exercises? |        |                  |

In-house audits confirm that the ISMS complies with ISO 27001 and internal policies.

This checklist ensures both the transparency and optimal implementation of audits, while leaving many roads paved for future progress.

Repeating internal audits mitigate the likelihood for nonconformities at the time of certification and inculcate organizational maturity.

## 9. Monitoring, Measurement, and Review Checklist (Clauses 9.1 & A.18)

| Checklist Item                                                                     | Yes/No | Remarks/Evidence |
|------------------------------------------------------------------------------------|--------|------------------|
| Are performance indicators (KPIs) defined for security effectiveness?              |        |                  |
| Are compliance audits and legal obligations reviewed periodically?                 |        |                  |
| Are trends in incidents and audit findings analyzed for improvement opportunities? |        |                  |
| Are management reviews held regularly with documented outcomes?                    |        |                  |
| Are measurable objectives (risk reduction, awareness level) tracked?               |        |                  |

This checklist keeps organizations from stumbling around as they fail to figure out first, how do we identify the threats, and secondly, what do we do when something happens. Annex A.16 prioritizes the issue of minimizing damage and returning to normal operational status rapidly. The importance of dealing with incidents in both a proactive manner and preserving evidence to retain trust and compliance.

## 10. Document Review and Maintenance Checklist (Clause 7.5)

| Checklist Item                                                      | Yes/No | Remarks/Evidence |
|---------------------------------------------------------------------|--------|------------------|
| Are document owners assigned for each ISMS document?                |        |                  |
| Is version control applied to prevent unauthorized modifications?   |        |                  |
| Are obsolete documents archived securely and prevented from reuse?  |        |                  |
| Are documents reviewed after major changes or at defined intervals? |        |                  |
| Is access to sensitive ISMS documents restricted?                   |        |                  |

Inspection career Inspection consists of two phases, monitoring and measurement. This table ensures that ISMS validity is data driven and there are quantifiable studies/reports as evidence. Clause 9.1 makes provision for the above on completion of verification of control action, or requirements, and / or their fitness for use in every instance. Transparency: Regular feedback informs our decision making for continued improvement.



## 11. Continual Improvement Checklist (Clause 10)

| Checklist Item                                               | Yes/No | Remarks/Evidence |
|--------------------------------------------------------------|--------|------------------|
| Are nonconformities recorded and tracked to closure?         |        |                  |
| Are root causes of recurring issues analyzed systematically? |        |                  |
| Are corrective and preventive actions implemented promptly?  |        |                  |
| Are improvements validated for effectiveness?                |        |                  |
| Is continual improvement discussed in management reviews?    |        |                  |

Clause 10 of ISO 27001 drives long-term success.

This checklist ensures organizations respond to lessons learned, audit findings, and emerging threats with measurable improvements.

Continuous improvement keeps the ISMS current and effective as business and technology evolve.

## 12. Risk Assessment Template (Sample)

| Asset           | Threat          | Vulnerability          | Impact | Likelihood | Risk Level | Treatment Action                | Responsible        |
|-----------------|-----------------|------------------------|--------|------------|------------|---------------------------------|--------------------|
| Customer Data   | Phishing Attack | Weak Email Filtering   | High   | Likely     | Very High  | Implement anti-phishing gateway | IT Security Lead   |
| Server Hardware | Power Outage    | Lack of UPS Redundancy | Medium | Possible   | Medium     | Install UPS and monitoring      | Facilities Manager |

This example shows a consistent approach to identification and the measurement of information security risks.

It demonstrates one of the core ideas behind risk-based thinking with ISO 27001:2022 considering how a threat relates to vulnerabilities and ensuring responsibilities for mitigation are defined.

## 13. Incident Register Example

| Incident ID | Date      | Category          | Severity | Root Cause         | Action Taken                            | Status |
|-------------|-----------|-------------------|----------|--------------------|-----------------------------------------|--------|
| IM-2025-01  | 4/22/2025 | Malware Infection | High     | Unpatched software | Applied patch and updated AV signatures | Closed |

This log template gives you traceable surveys of every accident.

Keeping a record of incidents meets the requirements of Annex A.16 and reinforces Clause 10 (continual improvement).

It demonstrates that incidents are investigated, recorded and resolved – the organization is being held accountable.

## 14. Integration with Other Management Systems

| Standard                             | Integration Benefit                                                |
|--------------------------------------|--------------------------------------------------------------------|
| ISO 9001:2015 (Quality Management)   | Unifies performance improvement processes and security management. |
| ISO 22301:2019 (Business Continuity) | Integrates recovery and resilience strategies with ISMS.           |
| ISO 31000:2018 (Risk Management)     | Aligns risk treatment and decision-making frameworks.              |

This table demonstrates interoperability under the Annex SL high-level structure.

Integration eliminates redundancy and supports multi-standard certification.

It also aligns information security with broader organizational governance systems for efficiency and strategic coherence.

## 15. Conclusion

The checklists and explanations contained in this manual provide a proven and rigorous model upon which to base your own ISO 27001:2022 implementation.

They allow all corporations to make the abstract standard criteria a reality as they can translate those into measurable and auditable behaviors.

By applying these checklists:

- Strategic leadership can guarantee oversight and compliance.
- Implementors can audit controls and risk reduction.
- Auditors would then be able to evaluate the ongoing progress and the soundness of your documentation.

In a nutshell, these checklists turn ISO 27001 from an compliance tool into a business enabler, helping you to align governance, security and resilience as part of a single regime of continual improvement.

## 16. References

- Aleksandrov, Mark N. and Vasiliev, Victor A. and Aleksandrova, Svetlana V. (2021). Implementation of the Risk-based Approach Methodology in Information Security Management Systems. 2021 International Conference on Quality Management, Transport and Information Security, Information Technologies (IT&QM&IS), (pp. 137-139).
- Guo, Huaqun and Wei, Meng and Huang, Ping and Chekole, Eyasu Getahun. (2021). Enhance Enterprise Security through Implementing ISO/IEC 27001 Standard. 2021 IEEE International Conference on Service Operations and Logistics, and Informatics (SOLI).
- (Third edition 2022-10). ISO/IEC 27001:2022 - Information Security Management Standards, International Organization for Standardization. INTERNATIONAL STANDARD.
- Malatji, Masike. (2023). Management of enterprise cyber security: A review of ISO/IEC 27001:2022. 2023 International Conference On Cyber Management And Engineering (CyMaEn).